OWASP Top 10:2021 — Beginner Cheat Sheet

Ten risk categories • Simple meaning • Defensive habit

A01 Broken Access Control Check permission on the server for every protected action and record.	**A02 Cryptographic Failures** Use HTTPS, safe password hashing, and protected secret storage.
A03 Injection Keep data separate from commands: use parameterized queries and safe APIs.	**A04 Insecure Design** Plan for abuse cases, security requirements, and least privilege.
A05 Security Misconfiguration Use secure defaults; turn off production debug; remove defaults.	**A06 Vulnerable Components** Inventory, review, and update supported libraries and frameworks.
A07 Authentication Failures Use trusted auth libraries and protect sessions and recovery flows.	**A08 Integrity Failures** Trust verified sources; protect build, update, and release processes.
A09 Logging & Monitoring Failures Record useful events, monitor them, and never log secrets.	**A10 SSRF** Restrict server-side URL fetching with allow-lists and network controls.

Remember: validate on the server • authorize every request • parameterize queries • encode output • protect secrets • update dependencies • log safely • verify AI advice.

Practice only on systems you own or approved training labs. AI output is a draft: verify against OWASP, NIST, MDN, and official framework documentation. Edition shown: OWASP Top 10:2021.